

用户管理系统 — 完整安全审计报告

项目名称：Flask 用户信息管理平台
审计日期：2026-07-13
漏洞总数：11
严重漏洞：8 | 中危漏洞：2 | 低危漏洞：1

漏洞清单

编号	漏洞类型	位置	严重性	CVSS
V-001	命令注入 (RCE)	/ping	严重	10.0
V-002	XXE 文件读取	/xml-import	严重	9.1
V-003	SSRF	/fetch-url	严重	9.1
V-004	CSRF 改密	/change-password	严重	8.6
V-005	越权改密	/change-password	严重	8.6
V-006	无原密码校验	/change-password	严重	8.6
V-007	IDOR 越权查资料	/profile?user_id=	严重	8.6
V-008	负金额充值	/recharge	严重	9.1
V-009	SQL注入 (搜索)	?keyword=	严重	9.1
V-010	路径穿越	/page?name=../	严重	8.6
V-011	任意文件上传	/upload	中危	8.2

1. V-002 XXE 外部实体注入

CWE: CWE-611: Improper Restriction of XML External Entity Reference

CVSS: 9.1 (Critical)

漏洞代码

```
import re
import xml.etree.ElementTree as ET

@app.route("/xml-import", methods=["POST"])
def xml_import():
    xml_data = request.form.get("xml_data", "")
    # 提取 SYSTEM 文件路径
    file_paths = re.findall(r'<!ENTITY\s+\w+\s+SYSTEM\s+"([^\"]+)"', xml_data)
    for fpath in file_paths:
        with open(fpath, "r") as f: # ← 直接读取文件
            file_content = f.read()
```

问题：主动提取 SYSTEM 后面的文件路径并读取文件内容，替换到 XML 中返回给用户。攻击者可读取服务器任意文件。

POC：读取系统文件

```
<!-- 提交以下 XML 数据 -->
<?xml version="1.0" encoding="UTF-8"?>
<!DOCTYPE foo [
  <!ENTITY xxe SYSTEM "file:///etc/passwd">
]>
<root>
  <user>
    <name>&xxe;</name>
    <email>test@test.com</email>
  </user>
</root>
```

```
curl -X POST http://127.0.0.1:5000/xml-import \
-d "xml_data=<?xml version='1.0'?><!DOCTYPE foo [<!ENTITY xxe SYSTEM 'file:///etc/passwd'>]><
```

可读取的文件

目标	路径	信息
系统密码文件	file:///etc/passwd	用户列表
应用源码	file:///path/to/app.py	代码逻辑、密钥

目标	路径	信息
数据库	file:///path/to/data/users.db	所有用户数据
SSH 密钥	file:///root/.ssh/id_rsa	服务器登录凭据
配置文件	file:///etc/nginx/nginx.conf	服务器配置

修复方案

```
# ☒ 方案1：禁用外部实体
parser = ET.XMLParser()
parser.parser.entity = {} # 禁用实体解析

# ☒ 方案2：使用 defusedxml 库
from defusedxml import ElementTree as DET
root = DET.fromstring(xml_data)

# ☒ 方案3：不解析实体，直接移除 DOCTYPE
xml_data = re.sub(r'<!DOCTYPE[^\>]*>', '', xml_data)

# ☒ 方案4：禁止读取本地文件
ALLOWED_PATHS = ["/path/to/allowed/dir"]
if not any(fpath.startswith(p) for p in ALLOWED_PATHS):
    raise ValueError("不允许读取该文件")
```

修复方法汇总

漏洞	问题	修复方案
V-001 命令注入	f-string + shell=True	参数化命令 + shell=False
V-002 XXE	读取SYSTEM指定文件	禁用外部实体/defusedxml
V-003 SSRF	无URL协议校验	协议白名单+内网IP黑名单
V-004~006 改密	无CSRF/越权/无原密码	CSRF+session校验+原密码
V-007 IDOR	user_id从URL取	从 session 获取
V-008 负金额	amount无校验	检查 amount>0
V-009 SQL 注入	f-string拼接	参数化查询

漏洞	问题	修复方案
V-010 路径穿越	直接拼接路径	realpath+前缀校验
V-011 文件上传	无校验	后缀白名单

报告日期：2026-07-13